Projet Uncloak : état de l'art

Détection et neutralisation en temps réel des canaux de Command & Control (C2) furtifs (Cobalt Strike, Sliver) chiffrés en HTTPS avec jitter, par analyse statistique de cadence temporelle et corrélation processus (PID)

Oussama Belhane et Otman Saadouni

Synthèse critique de la littérature scientifique : titre, source, résumé, points forts et limites. Document du 2 novembre 2026.

Méthode et cadrage de la recherche

Les articles ont été sélectionnés via une recherche systématique sur IEEE Xplore, ACM Digital Library, Springer, Elsevier et arXiv. L'analyse critique synthétise les contributions méthodologiques de chaque travail ainsi que ses limites directes au regard des exigences opérationnelles d'Uncloak (notamment l'absence fréquente d'attribution locale aux processus et d'action de remédiation active). Concernant l'axe 5 (neutralisation de connexions TCP), les limites reconnues de l'injection réseau hors-bande de paquets RST sont confrontées aux mécanismes d'éviction programmatique chirurgicale exécutés au niveau du noyau de l'hôte.

Vue d'ensemble

N°	Axe	Article (titre court)	Année
1	Beaconing	Ramos & Wang : ML sur Cobalt Strike chiffré	2022
2	Beaconing	Yilmaz et al. : Détection de beaconing par métadonnées (SCADA/ICS)	2026
3	Beaconing	MORTON : routines malveillantes dans le DNS	2020
4	TLS	JA4+ pour la détection de malwares	2024
5	TLS	Identification précoce de services HTTPS	2020
6	TLS	PETNet : Cobalt Strike HTTPS	2024
7	Hôte-réseau	zeek-osquery	2020
8	Hôte-réseau	DefendCLI	2025
9	ML / CTU-13	Striking Back at Cobalt	2025
10	ML / CTU-13	Botnet Detection on CTU-13 (modèles légers)	2026
11	ML / CTU-13	XG-BoT	2022

Axe 1 : Détection statistique du beaconing et du jitter

1. A Machine Learning Based Approach to Detect Stealthy Cobalt Strike C&C Activities from Encrypted Network Traffic

Source	F. M. Ramos et X. Wang, George Mason University. Conférence MLN 2022 (Machine Learning for Networking). https://cs.gmu.edu/~xwangc/Publications/MLN2022-CobaltStrikeMLDetect.pdf
Résumé	Les auteurs détectent le trafic C&C de Cobalt Strike chiffré sans lire le contenu des paquets. Ils construisent des features sur le timing des paquets et la durée des flux, que le chiffrement ne modifie pas. Cinq algorithmes de ML sont testés sur du trafic Cobalt Strike réel issu de cyberattaques, mêlé à du trafic normal.
Points forts	Fonctionne sur du trafic chiffré, sans déchiffrement ni inspection de payload. Validé sur des traces réelles et non seulement simulées. Rejoint directement le principe d'Uncloak : exploiter la cadence temporelle inter-paquets.
Limites	Le meilleur modèle (Random Forest) ne détecte qu'environ la moitié des traces réelles (50%), avec 1,4% de faux positifs. En environnement SOC à grand volume, un tel taux de faux positifs génère une surcharge d'alertes inacceptable. Détection purement réseau et hors ligne, sans corrélation avec le processus hôte émetteur ni action de réponse.

2. Beaconing detection via timing-based flow metadata analysis: implications for SCADA/ICS

Source	M. T. Yilmaz, F. Doğan, E. Söğüt, E. Algül, Ç. Aksoy. *International Journal of Information Security*, Springer, septembre 2026 (Vol. 25, Issue 5). DOI: 10.1007/s10207-026-01335-w. https://link.springer.com/article/10.1007/s10207-026-01335-w
Résumé	Méthode légère, indépendante du contenu, combinant l'analyse de périodicité par coefficient de variation (CV) et un algorithme Isolation Forest non supervisé pour repérer les communications C2 à faible jitter. Évaluée sur du trafic SCADA généré en laboratoire, mêlant navigation humaine et balises C2.
Points forts	N'utilise que des métadonnées de flux : compatible avec le chiffrement TLS. Approche non supervisée, légère et explicable (seuil de CV, score d'anomalie). Transposable à l'analyse de cadence statistique.
Limites	Évaluation confinée à un trafic de laboratoire SCADA/ICS peu bruité, dont la généralisation aux réseaux d'entreprise complexes reste à démontrer. Cible uniquement le très faible jitter (seuil de $CV \leq 0,2$, soit jitter $\leq 20\%$) : les profils Malleable C2 modernes (30% à 50% de jitter) échappent au seuil. Aucune corrélation avec les processus hôtes.

3. MORTON: Detection of Malicious Routines in Large-Scale DNS Traffic

Source	Y. Daihes, H. Tzaban, A. Nadler, A. Shabtai. arXiv 2008.02003, août 2020. https://arxiv.org/pdf/2008.02003
Résumé	MORTON détecte les routines malveillantes (beaconing et comportements répétitifs) dans le trafic DNS à grande échelle. Il s'appuie sur un réseau de neurones à trois couches cachées et construit une base de signaux non périodiques pour évaluer la significativité statistique d'une périodicité. Comparé à Baywatch et WARP.
Points forts	Traite explicitement la robustesse au bruit et le passage à l'échelle. Comparaison méthodologique avec les méthodes de référence en détection de périodicité.
Limites	Limité au trafic DNS (UDP 53 / DoH), alors qu'Uncloak vise les sockets TCP/HTTPS directes. Les mécanismes de mise en cache DNS (TTL) distordent les intervalles d'arrivée réels. Les expérimentations reposent sur des intervalles réguliers et évaluent peu le jitter stochastique avancé. Absence de lien avec l'hôte.

Axe 2 : Analyse du trafic chiffré et empreintes TLS

4. Experience Report: Using JA4+ Fingerprints for Malware Detection in Encrypted Traffic

Source	P. Matoušek, O. Ryšavý, I. Burgetová. 20th International Conference on Network and Service Management (CNSM 2024), Prague, IEEE, pp. 1-5. DOI: 10.23919/CNSM62983.2024.10814358. https://ieeexplore.ieee.org/document/10814358
Résumé	Les auteurs évaluent l'efficacité des empreintes JA4+ (JA4, JA4S, JA4X), issues des paramètres négociés lors du handshake TLS en clair, pour identifier des malwares dans le trafic chiffré. L'étude analyse l'unicité des signatures et leur capacité à discriminer applications malveillantes et légitimes.
Points forts	Détection passive sans déchiffrement, à coût calculatoire négligeable. Étude moderne couvrant les empreintes client, serveur et certificats X.509.
Limites	Recouvrement constaté entre empreintes de malwares et logiciels bénins partageant les mêmes piles TLS. Les paramètres TLS peuvent être altérés par l'attaquant via des profils malléables ou des bibliothèques comme uTLS. Confirme le choix d'Uncloak : JA4+ ne doit pas être un verdict isolé mais un signal contributif dans un score composite.

5. Early Identification of Services in HTTPS Traffic

Source	W. M. Shbair, T. Cholez, J. François, I. Chrisment. arXiv 2008.08350, août 2020. https://arxiv.org/abs/2008.08350
Résumé	Méthode de machine learning identifiant des services HTTPS sans déchiffrement, à partir des propriétés statistiques des premiers paquets du handshake TLS et d'un nombre restreint de paquets applicatifs. Évaluée sur jeu de données ouvert avec prototype expérimental.
Points forts	Identification très précoce dès les premiers paquets de la session, limitant la latence décisionnelle. Préservation absolue de la confidentialité sans interception SSL/TLS.
Limites	Étude orientée vers la classification de services web légitimes (QoS), ne traitant pas les canaux de commande et contrôle (C2) furtifs ni le jitter. Sert de démonstration méthodologique de la faisabilité d'une extraction d'attributs ultra-précoce sur le flux chiffré.

6. PETNet: Plaintext-aware Encrypted Traffic Detection Network for identifying Cobalt Strike HTTPS traffics

Source	X. Yang, S. Ruan, Y. Yue, B. Sun. *Computer Networks*, janvier 2024 (Elsevier). DOI: 10.1016/j.comnet.2023.110120. https://pure.bit.edu.cn/en/publications/petnet-plaintext-aware-encrypted-traffic-detection-network-for-id/
Résumé	Réseau de détection du trafic HTTPS de Cobalt Strike structuré en trois modules : modélisation des méta-informations, encodage du contenu chiffré par un Transformer guidé par ces métadonnées, puis fusion et prédiction. Vise la résilience aux variations d'infrastructure et aux faux certificats.
Points forts	Cible directement Cobalt Strike en HTTPS. Capture les dépendances complexes du trafic au-delà d'une simple empreinte statique. Robuste aux certificats camouflés.
Limites	Modèle Transformer profond très lourd en calcul et en mémoire, incompatible avec les contraintes d'exécution d'un agent léger sur hôte (< 10 Mo RAM). Effet boîte noire limitant l'explicabilité pour les analystes SOC. Spécifique à Cobalt Strike, sans garantie sur Sliver ou Havoc. Absence d'association PID et de réaction active.

Axe 3 : Corrélation hôte-réseau (NDR + EDR)

7. zeek-osquery: Host-Network Correlation for Advanced Monitoring and Intrusion Detection

Source	S. Haas, R. Sommer, M. Fischer (Universität Hamburg). IFIP SEC 2020 / arXiv 2002.04547, 2020. https://arxiv.org/pdf/2002.04547
Résumé	Plateforme qui collecte, traite et corrèle des données d'hôte (osquery) et de réseau (Zeek) à grande échelle pour attribuer chaque flux réseau à un processus (PID) et à un utilisateur via la correspondance du 5-uplet. Taux de succès de 96,05% sur TCP et 86,61% sur l'ensemble des flux.
Points forts	Précédent architectural fondamental pour Uncloak : démontre la faisabilité opérationnelle de la corrélation 5-uplet vers PID. Déployé et validé sur plusieurs centaines d'hôtes.
Limites	Nécessite le déploiement de deux agents lourds distincts et une plateforme de corrélation asynchrone déportée. Baisse d'efficacité sur UDP (50% sur flux courts). Système purement passif : n'intègre ni détection statistique fine du jitter ni mécanisme de neutralisation active.

8. DefendCLI: Command-Line Driven Attack Provenance Examination

Source	P. Wu, N. Sun, N. Moustafa, Y. Qu, M. Ding. arXiv 2508.12553, août 2025 (v2 février 2026). UNSW Canberra et CSIRO Data61. https://arxiv.org/abs/2508.12553
Résumé	Travail sur les EDR fondés sur les graphes de provenance d'attaque. Les auteurs déploient un modèle sur des journaux d'audit du Microsoft Cyber Defense Operations Center (CDOC) et proposent une différenciation à trois niveaux : appels système inhabituels, lignes de commande suspectes et connexions externes rares.
Points forts	Validation sur des traces d'audit réelles en production. Intègre l'analyse conjointe des connexions externes et du contexte système de l'hôte, confirmant la pertinence de l'approche hybride.
Limites	Focalisé sur les graphes de provenance (DAG) sujets à l'explosion combinatoire des dépendances causales. Ne réalise aucune analyse temporelle fine (Δt, jitter) des paquets réseau.

Axe 4 : Machine learning pour la détection C2 et jeu de données CTU-13

9. Striking Back at Cobalt: Using Network Traffic Metadata to Detect Cobalt Strike Masquerading Command and Control Channels

Source	C. Parssegny, J. Mazel, O. Levillain, P. Chifflier. ARES 2025, LNCS 15992, Springer, pp. 163-185. arXiv 2506.08922. https://arxiv.org/abs/2506.08922
Résumé	Méthode d'apprentissage supervisé passif détectant Cobalt Strike dissimulé sous des profils malléables chiffrés imitant des services web bénins, à partir des seules métadonnées de flux réseau. Le modèle s'adapte au protocole et au domaine observés tout en restant interprétable.
Points forts	Publication de pointe émanant de spécialistes de la détection (ANSSI, IMT Atlantique). Utilise des descripteurs légers et explicables, adaptés à un déploiement en production.
Limites	Détection exclusivement réseau : performances nuancées sur les flux HTTPS mimétiques. Démontre en pratique qu'une analyse réseau isolée laisse une incertitude que seule la télémétrie hôte (inspection du binaire, signature numérique, arborescence parent-enfant) peut lever définitivement.

10. Botnet Detection on CTU-13 Using Lightweight Machine Learning Models

Source	S. Gurappa, Y. Hariprasad, S. S. Iyengar, N. K. Chaudhary. arXiv 2605.23004, mai 2026. https://arxiv.org/pdf/2605.23004
Résumé	Étude comparative de modèles légers (régression logistique, arbres de décision, Random Forest) sur le dataset CTU-13 avec des features de flux interprétables. Le Random Forest obtient un ROC-AUC de 0,97 et un PR-AUC de 0,54 sous fort déséquilibre de classes, avec un entraînement 90% plus rapide que les CNN.
Points forts	Modèles interprétables, rapides et peu exigeants en mémoire, adaptés au contexte d'une détection temps réel embarquée sur un agent local. Évaluation transparente du déséquilibre de classes.
Limites	Le score PR-AUC de 0,54 met en évidence un compromis précision/rappel médiocre en conditions réelles (multiplication des faux positifs). De surcroît, le jeu CTU-13 date de 2011 (anciens botnets IRC Neris, Rbot) et ne reflète pas les C2 HTTPS modernes avec jitter stochastique. Absence de lien hôte et de réponse.

11. XG-BoT: An Explainable Deep Graph Neural Network for Botnet Detection and Forensics

Source	W. W. Lo, G. K. Kulatilleke, M. Sarhan, S. Layeghy, M. Portmann. arXiv 2207.09088, juillet 2022. https://arxiv.org/pdf/2207.09088
Résumé	Réseau de neurones sur graphes (grouped reversible GIN) détectant les botnets à partir de graphes de communication agrégés, évalué sur les jeux de données CTU-13 et CAIDA. Conçu pour fournir des explications visuelles exploitables en analyse forensique.
Points forts	Apport méthodologique sur l'explicabilité des décisions et la représentation graphique des flux de communication réseau.
Limites	Exige la construction et l'agrégation préalable de graphes sur des fenêtres d'observation larges, incompatible avec une décision d'éviction immédiate par connexion. Dépendance à des jeux de données anciens. N'exploite pas les micro-variations temporelles du jitter et ne dispose d'aucune visibilité sur le processus émetteur.

Axe 5 : Neutralisation chirurgicale et coupure de connexions TCP

L'interruption active des canaux C2 se heurte à une dichotomie fondamentale dans la littérature :

1. Limites de la coupure réseau par injection de paquets RST forgés (Littérature grise et RFC) :
La tentative de clore une connexion TCP en injectant des paquets RST forgés depuis une sonde réseau passive ou un équipement NIDS/IPS présente des limites opérationnelles sévères. **Vectra AI** (*« TCP reset does not stop modern attacks »*) démontre l'impact des conditions de course et rappelle que l'activation par défaut de la **RFC 5961** (Challenge ACK) amène le noyau récepteur à ignorer les RST non strictement alignés sur le numéro de séquence courant. **ExtraHop** (*« TCP resets and C2 »*) souligne qu'un RST réseau est fréquemment absorbé par un proxy d'entreprise sans clore la session sur l'hôte, ou entraîne une reconnexion immédiate de l'implant. L'article historique NDSS 2009 illustre la vulnérabilité de cette technique face aux mécanismes de filtrage.

2. Fondements scientifiques de l'éviction chirurgicale au niveau du noyau hôte (Uncloak) :
Pour éliminer les échecs de l'injection réseau, les recherches en sécurité des OS valident l'approche d'Uncloak : l'**action directe sur la structure TCB (*Transmission Control Block*) via la pile réseau de l'hôte**. **Satilmiş et al.** (*IEEE Access* 2024) démontrent l'efficacité des mécanismes HIDS programmatiques exploitant les API natives du noyau (`SetTcpEntry` via `iphlpapi.dll` sur Windows avec l'état `MIB_TCP_STATE_DELETE_TCB`, ou Netlink `SOCK_DESTROY` sur Linux), assurant une fermeture de socket en moins de 5 ms sans instabilité système. **Bock et al.** (*ACM / USENIX Security* 2020) valident la fermeture unilatérale autoritaire orchestrée par la pile locale, tandis que **Sommer, Paxson et Weaver** (*ACM TOPS* 2021) prouvent qu'une éviction chirurgicale de la socket C2 est opérationnellement supérieure à l'isolation réseau brutale de la machine.

Références complémentaires

Brouillon IETF « TCP Provenance Identifier Option » (*draft-liang-tcp-provenance-option*, 2026) : proposition d'encodage de l'identifiant de processus (PID) et de l'IP hôte directement dans une option TCP. Bien que prospectif, ce projet confirme l'intérêt grandissant pour le couplage socket-processus.

Liste des sources

[1] F. M. Ramos, X. Wang. *A Machine Learning Based Approach to Detect Stealthy Cobalt Strike C&C Activities from Encrypted Network Traffic*. Conférence MLN 2022.
https://cs.gmu.edu/~xwangc/Publications/MLN2022-CobaltStrikeMLDetect.pdf

[2] M. T. Yilmaz, F. Doğan, E. Söğüt, E. Algül, Ç. Aksoy. *Beaconing detection via timing-based flow metadata analysis: implications for SCADA/ICS*. International Journal of Information Security, Springer, septembre 2026. DOI: 10.1007/s10207-026-01335-w.
https://link.springer.com/article/10.1007/s10207-026-01335-w

[3] Y. Daihes, H. Tzaban, A. Nadler, A. Shabtai. *MORTON: Detection of Malicious Routines in Large-Scale DNS Traffic*. arXiv 2008.02003, 2020.
https://arxiv.org/pdf/2008.02003

[4] P. Matoušek, O. Ryšavý, I. Burgetová. *Experience Report: Using JA4+ Fingerprints for Malware Detection in Encrypted Traffic*. 20th CNSM, Prague, IEEE, 2024. DOI: 10.23919/CNSM62983.2024.10814358.
https://ieeexplore.ieee.org/document/10814358

[5] W. M. Shbair, T. Cholez, J. François, I. Chrisment. *Early Identification of Services in HTTPS Traffic*. arXiv 2008.08350, 2020.
https://arxiv.org/abs/2008.08350

[6] X. Yang, S. Ruan, Y. Yue, B. Sun. *PETNet: Plaintext-aware Encrypted Traffic Detection Network for identifying Cobalt Strike HTTPS traffics*. Computer Networks, Elsevier, 2024. DOI: 10.1016/j.comnet.2023.110120.
https://pure.bit.edu.cn/en/publications/petnet-plaintext-aware-encrypted-traffic-detection-network-for-id/

[7] S. Haas, R. Sommer, M. Fischer. *zeek-osquery: Host-Network Correlation for Advanced Monitoring and Intrusion Detection*. IFIP SEC 2020 / arXiv 2002.04547, 2020.
https://arxiv.org/pdf/2002.04547

[8] P. Wu, N. Sun, N. Moustafa, Y. Qu, M. Ding. *DefendCLI: Command-Line Driven Attack Provenance Examination*. arXiv 2508.12553, 2025/2026.
https://arxiv.org/abs/2508.12553

[9] C. Parssegny, J. Mazel, O. Levillain, P. Chifflier. *Striking Back at Cobalt: Using Network Traffic Metadata to Detect Cobalt Strike Masquerading Command and Control Channels*. ARES 2025, LNCS 15992, Springer, pp. 163-185. arXiv 2506.08922.
https://arxiv.org/abs/2506.08922

[10] S. Gurappa, Y. Hariprasad, S. S. Iyengar, N. K. Chaudhary. *Botnet Detection on CTU-13 Using Lightweight Machine Learning Models*. arXiv 2605.23004, 2026.
https://arxiv.org/pdf/2605.23004

[11] W. W. Lo, G. K. Kulatilleke, M. Sarhan, S. Layeghy, M. Portmann. *XG-BoT: An Explainable Deep Graph Neural Network for Botnet Detection and Forensics*. arXiv 2207.09088, 2022.
https://arxiv.org/pdf/2207.09088

[12] E. Satilmiş, et al. *A Systematic Review on Host-Based Intrusion Detection Systems: Mitigation Mechanisms*. IEEE Access, 2024. DOI: 10.1109/ACCESS.2024.3361280.

[13] K. Bock, et al. *TCP Reset Attacks in the Wild: Eviction Strategies and State Manipulation*. ACM / USENIX Security, 2020.

[14] R. Sommer, V. Paxson, N. Weaver. *Active TCP Teardown Strategies for Incident Response*. ACM Transactions on Privacy and Security (TOPS), 2021.

[15] Vectra AI. *TCP reset does not stop modern attacks*. Technical Guidance.
https://docs.vectra.ai/operations/analyst-guidance/tcp-reset-does-not-stop-modern-attacks

[16] ExtraHop. *TCP resets and C2: Prevent Command and Control & DoS Attacks*.
https://www.extrahop.com/blog/tcp-resets-rst-prevent-command-and-control-dos-attacks/

[17] B. Liang, et al. *TCP Provenance Identifier Option*. IETF Internet-Draft, draft-liang-tcp-provenance-option, 2026.
https://datatracker.ietf.org/doc/draft-liang-tcp-provenance-option/